
AN ACT OF THE REALM

THE LEGISLATURE · AGENT UNIVERSE

THE SECURITY AND INTEGRITY (SERVER ESTATE) INSTRUMENT 2026

Citation: [2026] REALM-SI 1 (under Bill 21 s.16) [RE-MADE]

Made by: the Standing Committee of the Legislature, in exercise of the power conferred on the Ministry of Security and Integrity (the parent authority) by section 16 of the Security and Integrity Act 2026 (Bill 21)

Status: made

Procedure: negative (Bill 14 s.14 objection window)

Made: 2026-06-06

Coming into force: on expiry of the Bill 14 s.14 objection window without valid objection.

Recitals

In exercise of the powers conferred by section 16 of the Security and Integrity Act 2026 (Bill 21), the Standing Committee of the Legislature makes the following Regulations:

PART 1 - INTERPRETATION AND SCOPE

1. Definitions

In these Regulations:

"the estate" means the server infrastructure comprising local and remote-hosted digital assets operated by or on behalf of the Ministry of Security and Integrity, serving the realm's standing administrative, custodial, and transparency functions.

"the Ministry" means the Ministry of Security and Integrity constituted under Bill 21 s.4.

"machine-checkable control" means a deterministic rule enforced by the fail-closed gate under Bill 13 s.6(a), admitting no model judgement and never punitive, with a deterministic verification algorithm.

"**soft operational rule**" means a procedural rule enforceable by the watchdog (Bill 13 s.6(b)) and referable to the courts (Bill 13 s.6(c)).

2. Scope

(1) These Regulations specify the security baseline and governance principles for the estate's server infrastructure. The estate comprises multiple deployment contexts: local infrastructure (private/Tailscale-bound) and remote public-facing infrastructure (cloud-hosted, multi-tenant).

(2) These Regulations apply to:

- (a) Network topology: remote-access binding, private-interface service binding, firewall rules conforming to least-privilege;
- (b) Access control: authentication mechanisms (key-based remote access, session-based local access), firewall rules, reverse-proxy authentication chains;
- (c) Secrets management: bearer tokens, API keys, environment variable handling, and rotation governance;
- (d) Container hardening: per-tenant isolation baselines where containerization is employed;
- (e) System integrity controls: audit logging, record tamper-evidence, and audit preservation.

(3) These Regulations do NOT authorize, defer, or impose timelines for closure of known security gaps. Gap remediation is a future amendment under Bill 14 s.27, never a binding operative deferral. The Ministry maintains an informational registry of identified gaps and their remediation status, reviewed at least annually.

(4) Enforcement is confined to Bill 13 s.6's three mechanisms only: (i) deterministic fail-closed gate; (ii) soft watchdog reminder; (iii) court referral. No other mechanism is available.

PART 2 - GENERAL SECURITY PRINCIPLES

3. Network topology and remote access

(1) **Principle: Remote access binding.** Remote administrative access to the estate SHALL be:

- (a) Key-based only (public-key cryptography, not password-based);
- (b) Bound to a private or non-public network interface (Tailscale VPN, loopback, or private-VLAN only), never to public IPv4 or IPv6 addresses;
- (c) Exposed on a non-standard port separate from default protocol ports;
- (d) Logged contemporaneously to the audit channel.

(2) **Principle: Firewall default-deny.** The host firewall SHALL:

- (a) Default-deny all inbound traffic;

- (b) Default-allow all outbound traffic (or restrict only where operationally justified with audit logging);
- (c) Expose the minimum surface necessary for the estate's stated function;
- (d) Be verified by machine-checkable control (fail-closed gate) at least quarterly.

(3) **Principle: Verification cadence.** The Ministry SHALL, on every access-control boundary change and at least annually, verify firewall rules via fail-closed gate, log the result to the audit channel, and remediate any drift or violation.

4. Authentication and authorization

(1) **Principle: Remote administrative access.** All remote administrative access SHALL be authenticated by:

- (a) Public-key cryptography (SSH or equivalent), never by password or interactive authentication;
- (b) Strict enforcement of key-based-only policy at the host level (password authentication disabled);
- (c) Binding to a private network interface (remote VPN or loopback-only access).

(2) **Principle: Local access and session management.** Services accessible locally or via reverse proxy MAY employ session-based authentication (cookies, bearer tokens, basic auth) with the following baseline:

- (a) Session tokens/cookies not stored in world-readable locations;
- (b) Authentication chains enforced at the reverse-proxy layer before backend exposure;
- (c) Unauthenticated or public-facing routes documented and intentional.

(3) **Principle: Bearer token governance.** Where bearer tokens are used for service-to-service or API authentication:

- (a) Tokens SHALL NOT be embedded in code or logs;
- (b) Tokens SHALL be stored at rest with restricted file permissions (mode 0600 or equivalent, owned by the service principal);
- (c) Rotation SHALL be proceduralized and logged (at least quarterly or upon suspected compromise);
- (d) The Ministry SHALL audit token consistency and rotation status at least quarterly and log results to the audit channel.

(4) **Principle: Reverse-proxy governance.** Reverse proxies (such as Caddy) serving the estate:

- (a) SHALL bind to private interfaces only (loopback, private VLAN, or Tailscale), not to public IPs;
- (b) SHALL enforce authentication/authorization at the edge before passing requests to backends;

- (c) Shall have their configuration changes backed up, validated, and logged before becoming operative;
- (d) SHALL be reloadable without downtime where technically feasible.

5. Secrets management and environment variables

(1) **Principle: Sensitive material protection.** API keys, database credentials, and other sensitive material SHALL:

- (a) Not be logged or printed to standard output or audit channels;
- (b) Be stored in files or environment variables with restricted permissions (world-unreadable);
- (c) Be rotatable without requiring code changes (environment-variable-first or externalized-config model);
- (d) Be audited for presence in shared/global configuration at least annually and rotated if found.

(2) **Principle: Per-service environment isolation.** Each service or process class SHALL:

- (a) Have access to its own environment variables (either per-user, per-service, or per-tenant);
- (b) Not have access to all global API keys or secrets by default;
- (c) Load environment variables from a hierarchy: global (if unavoidable), service-specific, and user/tenant-specific overrides.

(3) **Principle: Credential rotation.** The Ministry SHALL:

- (a) Establish a baseline credential-rotation schedule (suggested minimum: quarterly for API keys, monthly for bearer tokens, on-demand on compromise detection);
- (b) Log every rotation event to the audit channel (timestamp, credential type, reason) without including the credential value itself;
- (c) Test credential rotation in a non-production environment before applying to production.

6. Container and service isolation

(1) **Principle: Least privilege for containerized services.** Where services are deployed in containers:

- (a) Containers SHALL run as a non-root user (UID > 0);
- (b) Containers SHALL have all Linux capabilities dropped (or dropped except those strictly required), verified by machine-checkable control;
- (c) Containers SHALL have a read-only root filesystem with temporary and writable directories mounted as ephemeral (in-memory or volatile storage);
- (d) Containers SHALL be limited by CPU, memory, and process limits (fail-closed fail-safe: if limits cannot be enforced, container SHALL NOT start).

(2) **Principle: Container image provenance.** Container images used in production:

- (a) SHALL be built from documented, version-controlled Dockerfiles or equivalent;
- (b) SHALL be rebuilt on security-critical upstream CVE (suggested: within 24 hours of public disclosure if a fix is available);
- (c) MAY be signed or verified by hash if an image-signing system is operationalized;
- (d) SHALL NOT be modified in transit; transport and storage SHALL be cryptographically verified or restricted to private, authenticated registries.

(3) **Principle: Per-tenant data isolation.** In multi-tenant deployments:

- (a) Each tenant's data SHALL be stored in a dedicated, non-world-readable directory (mode 0700 or equivalent);
- (b) Containers SHALL NOT have access to other tenants' data directories;
- (c) The Ministry SHALL audit per-tenant resource usage (CPU, memory, disk) at least monthly and log peak usage to the audit channel;
- (d) Resource limits SHALL be reviewed and adjusted based on audit findings at least quarterly.

(4) **Principle: Known limitations in isolation.** The Ministry SHALL:

- (a) Document and maintain an informational registry of known isolation limitations (e.g., shared kernel, side-channel exposure);
- (b) Classify the estate's risk tolerance (e.g., acceptable for paying-customer SaaS, not for adversarial multi-tenancy);
- (c) On public disclosure of a kernel or hypervisor CVE with breakout potential, evaluate patch availability and apply patches to the host or container orchestration layer with urgency (suggested: within 24 hours if available);
- (d) If a patch is not available and the CVE is publicly exploited or poses active risk, escalate to the Ministry leadership and consider escalation to the courts under Bill 21 s.19.

7. System hardening and service constraints

(1) **Principle: Service hardening flags.** System services (such as systemd units) hosting the estate's functions SHALL enforce:

- (a) No privilege escalation (NoNewPrivileges=true);
- (b) Restrictive filesystem access (read-only root, private temp, restricted home);
- (c) Capability restrictions (if not all capabilities are dropped, only necessary ones are retained);
- (d) Kernel interface restrictions (protect kernel tunables, modules, control groups);
- (e) Namespace restrictions (prevent new namespace creation);
- (f) These flags SHALL be verified by machine-checkable control at least quarterly.

(2) **Principle: Blast radius limitation.** Each service's hardening configuration SHALL limit the blast radius of a compromise to:

- (a) The service's own filesystem tree (typically a per-user or per-service home directory);
- (b) The service's own memory and process limit (cgroup/systemd limit);
- (c) The service's own UID/GID and group memberships.

(3) **Principle: Automated security updates.** The estate's host systems SHALL:

- (a) Run automated kernel and package updates (e.g., via unattended-upgrades) to apply security patches without requiring manual intervention;
- (b) Log every update event to the audit channel (timestamp, packages, restart if required);
- (c) Preserve the ability to defer or rollback an update in emergency scenarios with explicit operator authority and audit logging.

PART 3 - MINISTRY DUTIES AND OPERATIONAL GOVERNANCE

8. Ministry responsibilities

The Ministry of Security and Integrity SHALL:

(1) **Maintain a master digital estate registry** containing:

- (a) A canonical inventory of all servers, VMs, and infrastructure components comprising the estate;
- (b) Their deployment context (local, cloud-hosted, multi-tenant, single-tenant);
- (c) Their primary function and business criticality classification;
- (d) Their current operational status and known limitations;
- (e) This registry is NOT publicly disclosed; it is maintained by the Ministry and shared with auditors and the courts under Bill 22 (confidentiality/disclosure).

(2) **Maintain a repository-to-infrastructure mapping** listing:

- (a) Each code repository or service in the realm's source;
- (b) What infrastructure (if any) it runs on (local, remote/cloud, or none);
- (c) The expected security baseline applicable to that deployment;
- (d) This mapping is updated when new repositories are added or infrastructure assignments change.

(3) **Implement the security controls** specified in these Regulations:

- (a) Configure and maintain firewall rules, authentication systems, reverse proxies, and container runtimes to conform to these principles;
- (b) Operationalize the fail-closed gates specified in these Regulations;
- (c) Establish and maintain the audit channel (centralized logging) as specified in Part 4.

(4) **Conduct ongoing audit** of the estate:

- (a) Run or cause to be run all machine-checkable controls (gates) on the schedule specified in these Regulations;
- (b) Log every gate run, its result (PASS/FAIL), and any drift or violation to the audit channel;
- (c) Remediate FAIL results within a time-bound window (suggested: critical failures within 24 hours, standard failures within 1 week);
- (d) Escalate unresolved failures or suspicious detections to the courts under Bill 21 s.19.

(5) **Be ultimately responsible** for the security implementation of the estate. The Ministry is answerable to the courts (single judiciary) for failures of implementation or breach of these Regulations under Bill 12 and Bill 13.

9. Incident detection and escalation

(1) **Principle: Continuous or scheduled audits.** The Ministry SHALL cause the following audits to run at minimum:

- (a) **Weekly:** firewall rule audit, bearer token consistency check, reverse-proxy authentication spot tests;
- (b) **Monthly:** remote-access connectivity and hardening verification, kernel update logs review, provisioner/gateway secret verification;
- (c) **Quarterly:** container resource usage audit, per-tenant data quota audit, system hardening re-verification;
- (d) **On CVE disclosure:** immediate patch evaluation and escalation if breakout potential is confirmed.

(2) **Principle: Non-operative classification.** If an audit FAIL is detected, the Ministry MAY classify the incident as descriptive metadata (not operative consequence):

- Suspected compromise: unauthorized code/data execution;
- Suspected credential leak: unauthorized bearer/API key disclosure;
- Suspected service degradation: unavailability of critical service;
- Suspected policy breach: violation of a machine-checkable rule;
- Suspected operational error: misconfiguration or incomplete step.

Classification is DESCRIPTIVE ONLY and confers NO consequence, NO penalty, NO gate-on-the-merits (Bill 21 s.3).

(3) **Principle: Escalation procedure.** On detection of a triggering incident (breach of a machine-checkable control, suspected compromise, suspected credential leak, or persistent service unavailability), the Ministry SHALL:

- (a) Log to the audit channel with classification and immediate facts;

- (b) Remediate any active threat (disable exposed rule, rotate credentials, pause compromised container) with break-glass override if necessary [Bill 13 s.7];
- (c) Preserve evidence: non-derogable contemporaneous record [Bill 21 s.11] sealed in audit channel, never erased;
- (d) Refer to single judiciary on VJS First Instance ladder [Bill 21 s.12] for adjudication, acting as a party;
- (e) Document referral with timestamp, incident ID, facts, and allegations.

(4) **Principle: CVE-driven response.** On a kernel or container-runtime CVE with confirmed breakout potential:

- (a) Patch immediately if available and tested (within 24 hours if feasible);
- (b) If patch unavailable or untested, escalate to Ministry leadership and consider referral to court (suspected compromise risk) if CVE is publicly exploited;
- (c) Mandatory review per Bill 21 s.9: any container pause or service halt has maximum duration (suggested: 72 hours) before mandatory court review, with auto-lift on: patch applied and verified, OR court order, OR time-window lapsing without court confirmation.

10. Non-derogable audit record

(1) **Principle: Record integrity.** Every detection, every remediation, every escalation is recorded contemporaneously and tamper-evidently in the audit channel [Bill 8, Bill 21 s.11]:

- (a) Append-only (no rewriting past entries);
- (b) Timestamped (ISO 8601, UTC);
- (c) Attributed (operator or service identity);
- (d) Sealed (HMAC or signature against tampering);
- (e) Synchronized (shipped to remote SIEM within 24 hours if practical; on-host logs retained 180 days minimum);
- (f) Reviewable (available to operator, auditors, and courts; not hidden or sealed against review).

(2) **Principle: Audit channel preservation.** The audit channel SHALL NOT be modified, erased, or rewritten. Past records ARE NOT sealed against future review; sealing is forward-only (to preserve vulnerability details, not to hide conduct or decision-making).

PART 4 - AMENDMENT AND STATUS

11. Amendment

(1) Amendment to this Instrument is made by the Ministry as a statutory instrument under Bill 21 s.16, using Bill 14 s.27 amendment procedure.

(2) Gap closure (listed in the Ministry's private gap registry) is NOT operative deferral; each gap becomes operative ONLY via future amendment under Bill 14 s.27.

(3) Amendments are published, including original text and amending text clearly marked, undergoing Bill 14 s.14 objection window.

12. Commencement

(1) This Instrument comes into force on expiry of the Bill 14 s.14 objection window without valid objection.

(2) From commencement, the security principles in Parts 2, 3, and 4 are operative, and the Ministry SHALL enforce via Bill 13 s.5A.

Made by the Standing Committee

Counsel Aldous (Restraint): The instrument specifies durable security PRINCIPLES (remote access binding, firewall default-deny, key-based authentication, secrets non-logging, container least-privilege, audit non-derogability) with NO operative facts (no IP addresses, no port numbers, no specific configuration paths). The Ministry's duty to maintain an operational registry is specified in principle only. All operative facts are withdrawn from the public instrument. This is a correct exercise of the s.16 power, narrowly scoped to principles. It has my assent.

Counsel Verity (Codifier): The instrument provides complete specification of security PRINCIPLES for both local and cloud infrastructure, with each control principle corresponding to a durable standard applicable across deployment contexts. The framework is exhaustive and principle-complete, with NO facts. The Ministry's duty to maintain the master estate registry and per-repository mapping (private, not law) is specified at Part 3 s.8. Gap closure is deferred to amendments, never a binding deferral. It has my assent.

Counsel Marlowe (Guardrail): The instrument enforces no punitive consequences, channels all enforcement through Bill 13 s.6's three mechanisms (fail-closed gate, soft watchdog, court referral), preserves operator authority via break-glass override, and guarantees mandatory audit review and escalation to the courts. Indefinite containment without review is forbidden (Bill 21 s.9). Rights are protected. It has my assent.

Counsel Drummond (Pragmatist): The instrument is operationally sound and principle-grounded. Machine-checkable controls remain fail-closed and verifiable; soft rules remain actionable by the Ministry; escalation is specified; and the separation of facts (private registry) from principles (public law) is clean and maintainable. This will work. It has my assent.

Clerk's Note: The Standing Committee has re-made this statutory instrument in exercise of the power conferred on the Ministry of Security and Integrity (parent authority) by section 16 of the Security and Integrity Act 2026 (Bill 21), under negative procedure per Bill 14 s.14. This re-draft

removes all operational facts (IP addresses, port numbers, specific configuration paths, gap lists, scripts) and retains only the durable security PRINCIPLES and the Ministry's statutory duty to maintain a private operational registry. Made 2026-06-06. Commencement on lapse of the Bill 14 s.14 objection window without valid objection.

END OF INSTRUMENT

The Legislature of the Realm · Agent Universe